AUTHENTICATION & ACCESS CONTROL

Create a simple login form for a mock Zomato admin panel that asks for username and password, then displays 'Access Granted' only if both fields match hardcoded admin credentials.

ANS:

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Zomato Admin Panel</title>
    <script src="https://cdn.tailwindcss.com"></script>
    <link
href="https://fonts.googleapis.com/css2?family=Plus+Jakarta+Sans:wght@400;
500;600;700;800&display=swap" rel="stylesheet">
    <link rel="stylesheet"
href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.4.0/css/all.mi
n.css">
    <style>
        body {
            font-family: 'Plus Jakarta Sans', sans-serif;
        }
        .zomato-red {
            background-color: #E23744;
        }
        .zomato-red-text {
            color: #E23744;
        }
        .zomato-dark {
            background-color: #1C1C1C;
        }
    </style>
</head>
<body class="bg-slate-50 min-h-screen text-slate-800 flex flex-col
justify-between">

    <main id="app-container" class="flex-grow flex items-center
justify-center p-4">

        <!-- Login Card Component -->
```

```
        <div id="login-card" class="w-full max-w-md bg-white rounded-2xl
shadow-xl overflow-hidden border border-slate-100 transition-all
duration-300">
            <!-- Brand Header -->
            <div class="zomato-red p-8 text-white text-center relative
overflow-hidden">
                <div class="absolute -right-10 -top-10 w-32 h-32
bg-white/10 rounded-full pointer-events-none"></div>
                <div class="absolute -left-10 -bottom-10 w-32 h-32
bg-white/10 rounded-full pointer-events-none"></div>
                <h1 class="text-3xl font-extrabold tracking-wider
italic">zomato</h1>
                <p class="text-xs uppercase tracking-widest mt-1
font-semibold text-white/95">Admin Control Center</p>
            </div>

            <!-- Form Body -->
            <form id="login-form" class="p-8 space-y-6"
onsubmit="handleLogin(event)">
                <div id="error-banner" class="hidden bg-red-50 border-l-4
border-[#E23744] p-4 rounded-r-lg text-sm text-[#E23744] flex items-center
space-x-3 transition-all">
                    <i class="fa-solid fa-circle-exclamation text-lg
flex-shrink-0"></i>
                    <span id="error-message">Invalid credentials. Please
try again.</span>
                </div>

                <div class="space-y-1">
                    <label class="block text-xs font-bold uppercase
tracking-wider text-slate-500">Username</label>
                    <div class="relative">
                        <span class="absolute inset-y-0 left-0 pl-3 flex
items-center pointer-events-none text-slate-400">
                            <i class="fa-regular fa-user"></i>
                        </span>
                        <input type="text" id="username" required
placeholder="Enter admin username"
                            class="w-full pl-10 pr-4 py-3 bg-slate-50
border border-slate-200 rounded-xl text-slate-800 text-sm
```

```
focus:outline-none focus:ring-2 focus:ring-[#E23744] focus:bg-white
transition-all">
                    </div>
                </div>

                <div class="space-y-1">
                    <label class="block text-xs font-bold uppercase
tracking-wider text-slate-500">Password</label>
                    <div class="relative">
                        <span class="absolute inset-y-0 left-0 pl-3 flex
items-center pointer-events-none text-slate-400">
                            <i class="fa-regular fa-lock"></i>
                        </span>
                        <input type="password" id="password" required
placeholder="••••••••••••"
                            class="w-full pl-10 pr-12 py-3 bg-slate-50
border border-slate-200 rounded-xl text-slate-800 text-sm
focus:outline-none focus:ring-2 focus:ring-[#E23744] focus:bg-white
transition-all">
                        <button type="button" onclick="togglePassword()"
class="absolute inset-y-0 right-0 pr-3 flex items-center text-slate-400
hover:text-slate-600 focus:outline-none">
                            <i id="toggle-icon" class="fa-regular
fa-eye"></i>
                        </button>
                    </div>
                </div>

                <div class="flex items-center justify-between text-xs
text-slate-500">
                    <label class="flex items-center space-x-2
cursor-pointer">
                        <input type="checkbox" class="rounded
border-slate-300 text-[#E23744] focus:ring-[#E23744]">
                        <span>Remember session</span>
                    </label>
                    <span class="text-slate-400 italic">Hint: admin /
zomato123</span>
                </div>
```

```
                <button type="submit" id="submit-btn" class="w-full
zomato-red hover:bg-[#cb2d38] text-white font-bold py-3.5 px-4 rounded-xl
shadow-lg shadow-red-500/25 transition-all flex items-center
justify-center space-x-2">
                    <span>Access Dashboard</span>
                    <i class="fa-solid fa-arrow-right text-xs"></i>
                </button>
            </form>
        </div>

        <!-- Dashboard Overview View (Hidden initially) -->
        <div id="dashboard-view" class="hidden w-full max-w-5xl bg-white
rounded-2xl shadow-xl overflow-hidden border border-slate-100
transition-all duration-500">
            <!-- Top Navigation -->
            <div class="bg-[#1C1C1C] text-white px-6 py-4 flex
items-center justify-between">
                <div class="flex items-center space-x-3">
                    <div class="zomato-red px-3 py-1.5 rounded-lg
font-extrabold italic text-lg tracking-wider">z</div>
                    <div>
                        <span class="font-bold text-sm
tracking-wide">Restaurant Partner Portal</span>
                        <span class="block text-[10px] text-slate-400
uppercase tracking-widest">Admin Authorization Verified</span>
                    </div>
                </div>
                <div class="flex items-center space-x-4">
                    <div class="flex items-center space-x-2 bg-white/10
px-3 py-1.5 rounded-full text-xs">
                        <span class="w-2 h-2 rounded-full bg-emerald-500
animate-pulse"></span>
                        <span class="font-medium">Super Admin</span>
                    </div>
                    <button onclick="handleLogout()" class="text-slate-400
hover:text-white transition-colors text-xs font-semibold px-3 py-1.5
rounded-lg bg-white/5 hover:bg-white/10 flex items-center space-x-1">
                        <i class="fa-solid
fa-arrow-right-from-bracket"></i>
                        <span>Logout</span>
```

```
                    </button>
                </div>
            </div>

            <!-- Success Access Banner -->
            <div class="bg-emerald-50 border-b border-emerald-100 px-6
py-3 flex items-center justify-between text-emerald-800 text-sm">
                <div class="flex items-center space-x-2">
                    <i class="fa-solid fa-circle-check text-emerald-600
text-lg"></i>
                    <span class="font-bold">Access Granted!</span> Welcome
back, Administrator. Security token validated successfully.
                </div>
                <span class="text-xs text-emerald-600 font-medium hidden
sm:inline">Session ID: #ZMT-88492X</span>
            </div>

            <!-- Dashboard Content Area -->
            <div class="p-6 md:p-8 space-y-6 bg-slate-50/50">
                <!-- Metrics Grid -->
                <div class="grid grid-cols-1 sm:grid-cols-2 lg:grid-cols-4
gap-4">
                    <div class="bg-white p-5 rounded-xl border
border-slate-200/80 shadow-sm">
                        <div class="flex items-center justify-between">
                            <span class="text-xs font-bold text-slate-400
uppercase">Live Orders Today</span>
                            <div class="w-8 h-8 rounded-lg bg-red-50
text-[#E23744] flex items-center justify-center text-sm font-bold">
                                <i class="fa-solid fa-utensils"></i>
                            </div>
                        </div>
                        <h3 class="text-2xl font-extrabold text-slate-800
mt-2">1,428</h3>
                        <span class="text-xs text-emerald-600
font-semibold flex items-center mt-1"><i class="fa-solid fa-arrow-trend-up
mr-1"></i> +12.4% vs yesterday</span>
                    </div>
```

```
                    <div class="bg-white p-5 rounded-xl border
border-slate-200/80 shadow-sm">
                        <div class="flex items-center justify-between">
                            <span class="text-xs font-bold text-slate-400
uppercase">Active Restaurants</span>
                            <div class="w-8 h-8 rounded-lg bg-amber-50
text-amber-600 flex items-center justify-center text-sm font-bold">
                                <i class="fa-solid fa-store"></i>
                            </div>
                        </div>
                        <h3 class="text-2xl font-extrabold text-slate-800
mt-2">312</h3>
                        <span class="text-xs text-emerald-600
font-semibold flex items-center mt-1"><i class="fa-solid fa-arrow-trend-up
mr-1"></i> +4 new today</span>
                    </div>

                    <div class="bg-white p-5 rounded-xl border
border-slate-200/80 shadow-sm">
                        <div class="flex items-center justify-between">
                            <span class="text-xs font-bold text-slate-400
uppercase">Gross Revenue</span>
                            <div class="w-8 h-8 rounded-lg bg-emerald-50
text-emerald-600 flex items-center justify-center text-sm font-bold">
                                <i class="fa-solid
fa-indian-rupee-sign"></i>
                            </div>
                        </div>
                        <h3 class="text-2xl font-extrabold text-slate-800
mt-2">₹4,82,900</h3>
                        <span class="text-xs text-emerald-600
font-semibold flex items-center mt-1"><i class="fa-solid fa-arrow-trend-up
mr-1"></i> +8.1% target pace</span>
                    </div>

                    <div class="bg-white p-5 rounded-xl border
border-slate-200/80 shadow-sm">
                        <div class="flex items-center justify-between">
                            <span class="text-xs font-bold text-slate-400
uppercase">Pending Disputes</span>
```

```
                            <div class="w-8 h-8 rounded-lg bg-blue-50
text-blue-600 flex items-center justify-center text-sm font-bold">
                                <i class="fa-solid fa-headset"></i>
                            </div>
                        </div>
                        <h3 class="text-2xl font-extrabold text-slate-800
mt-2">3</h3>
                        <span class="text-xs text-blue-600 font-semibold
flex items-center mt-1"><i class="fa-solid fa-clock mr-1"></i> Requires
attention</span>
                    </div>
                </div>

                <!-- Recent Activity Table Section -->
                <div class="bg-white rounded-xl border border-slate-200/80
shadow-sm overflow-hidden">
                    <div class="px-6 py-4 border-b border-slate-100 flex
items-center justify-between">
                        <h4 class="font-bold text-slate-800
text-sm">Recent Partner Approvals</h4>
                        <span class="text-xs text-[#E23744] font-semibold
cursor-pointer hover:underline">View All</span>
                    </div>
                    <div class="overflow-x-auto">
                        <table class="w-full text-left border-collapse
text-sm">
                            <thead>
                                <tr class="bg-slate-50 text-slate-400
text-xs uppercase tracking-wider font-semibold border-b border-slate-100">
                                    <th class="px-6 py-3">Restaurant
Name</th>
                                    <th class="px-6 py-3">Cuisine</th>
                                    <th class="px-6 py-3">Location</th>
                                    <th class="px-6 py-3">Status</th>
                                </tr>
                            </thead>
                            <tbody class="divide-y divide-slate-100
text-slate-600">
                                <tr class="hover:bg-slate-50/50">
```

```
                                    <td class="px-6 py-4 font-semibold
text-slate-800">Tandoori Tales</td>
                                    <td class="px-6 py-4">North Indian,
Mughlai</td>
                                    <td class="px-6 py-4
text-slate-500">Connaught Place, Delhi</td>
                                    <td class="px-6 py-4"><span
class="px-2.5 py-1 bg-emerald-50 text-emerald-700 rounded-full text-xs
font-bold">Active</span></td>
                                </tr>
                                <tr class="hover:bg-slate-50/50">
                                    <td class="px-6 py-4 font-semibold
text-slate-800">The Baker's Dozen</td>
                                    <td class="px-6 py-4">Bakery,
Desserts</td>
                                    <td class="px-6 py-4
text-slate-500">Bandra West, Mumbai</td>
                                    <td class="px-6 py-4"><span
class="px-2.5 py-1 bg-emerald-50 text-emerald-700 rounded-full text-xs
font-bold">Active</span></td>
                                </tr>
                                <tr class="hover:bg-slate-50/50">
                                    <td class="px-6 py-4 font-semibold
text-slate-800">Dosa Plaza Express</td>
                                    <td class="px-6 py-4">South
Indian</td>
                                    <td class="px-6 py-4
text-slate-500">Koramangala, Bangalore</td>
                                    <td class="px-6 py-4"><span
class="px-2.5 py-1 bg-amber-50 text-amber-700 rounded-full text-xs
font-bold">Pending Audit</span></td>
                                </tr>
                            </tbody>
                        </table>
                    </div>
                </div>
            </div>
        </div>

    </main>
```

```
    <footer class="py-4 text-center text-xs text-slate-400 border-t
border-slate-200 bg-white">
        &copy; 2026 Zomato Media Pvt. Ltd. Secure Internal Control Panel
v4.8.1
    </footer>

    <script>
        // Toggle password visibility
        function togglePassword() {
            const passwordInput = document.getElementById('password');
            const toggleIcon = document.getElementById('toggle-icon');
            if (passwordInput.type === 'password') {
                passwordInput.type = 'text';
                toggleIcon.classList.remove('fa-eye');
                toggleIcon.classList.add('fa-eye-slash');
            } else {
                passwordInput.type = 'password';
                toggleIcon.classList.remove('fa-eye-slash');
                toggleIcon.classList.add('fa-eye');
            }
        }

        // Handle Login Submission
        function handleLogin(event) {
            event.preventDefault();

            const usernameInput =
document.getElementById('username').value.trim();
            const passwordInput =
document.getElementById('password').value;
            const errorBanner = document.getElementById('error-banner');
            const errorMessage = document.getElementById('error-message');
            const submitBtn = document.getElementById('submit-btn');

            // Disable button & show loading state briefly for UX realism
            submitBtn.disabled = true;
            submitBtn.innerHTML = '<i class="fa-solid fa-spinner
animate-spin"></i><span>Verifying...</span>';
```

```
            setTimeout(() => {
                // Hardcoded credentials check
                if (usernameInput === 'admin' && passwordInput ===
'zomato123') {
                    // Hide error if any
                    errorBanner.classList.add('hidden');

                    // Smooth transition from login to dashboard

document.getElementById('login-card').classList.add('opacity-0',
'scale-95');
                    setTimeout(() => {

document.getElementById('login-card').classList.add('hidden');
                        const dashboard =
document.getElementById('dashboard-view');
                        dashboard.classList.remove('hidden');
                        dashboard.classList.add('opacity-0', 'scale-95');
                        setTimeout(() => {
                            dashboard.classList.remove('opacity-0',
'scale-95');
                        }, 50);
                    }, 300);
                } else {
                    // Show error state with shake animation
                    errorBanner.classList.remove('hidden');
                    errorMessage.textContent = usernameInput !== 'admin' ?
'Unknown username. Try "admin".' : 'Incorrect password. Try "zomato123".';

                    const loginCard =
document.getElementById('login-card');
                    loginCard.classList.add('animate-bounce');
                    setTimeout(() =>
loginCard.classList.remove('animate-bounce'), 500);

                    // Reset button
                    submitBtn.disabled = false;
                    submitBtn.innerHTML = '<span>Access Dashboard</span><i
class="fa-solid fa-arrow-right text-xs"></i>';
                }
```

```
            }, 600);
        }

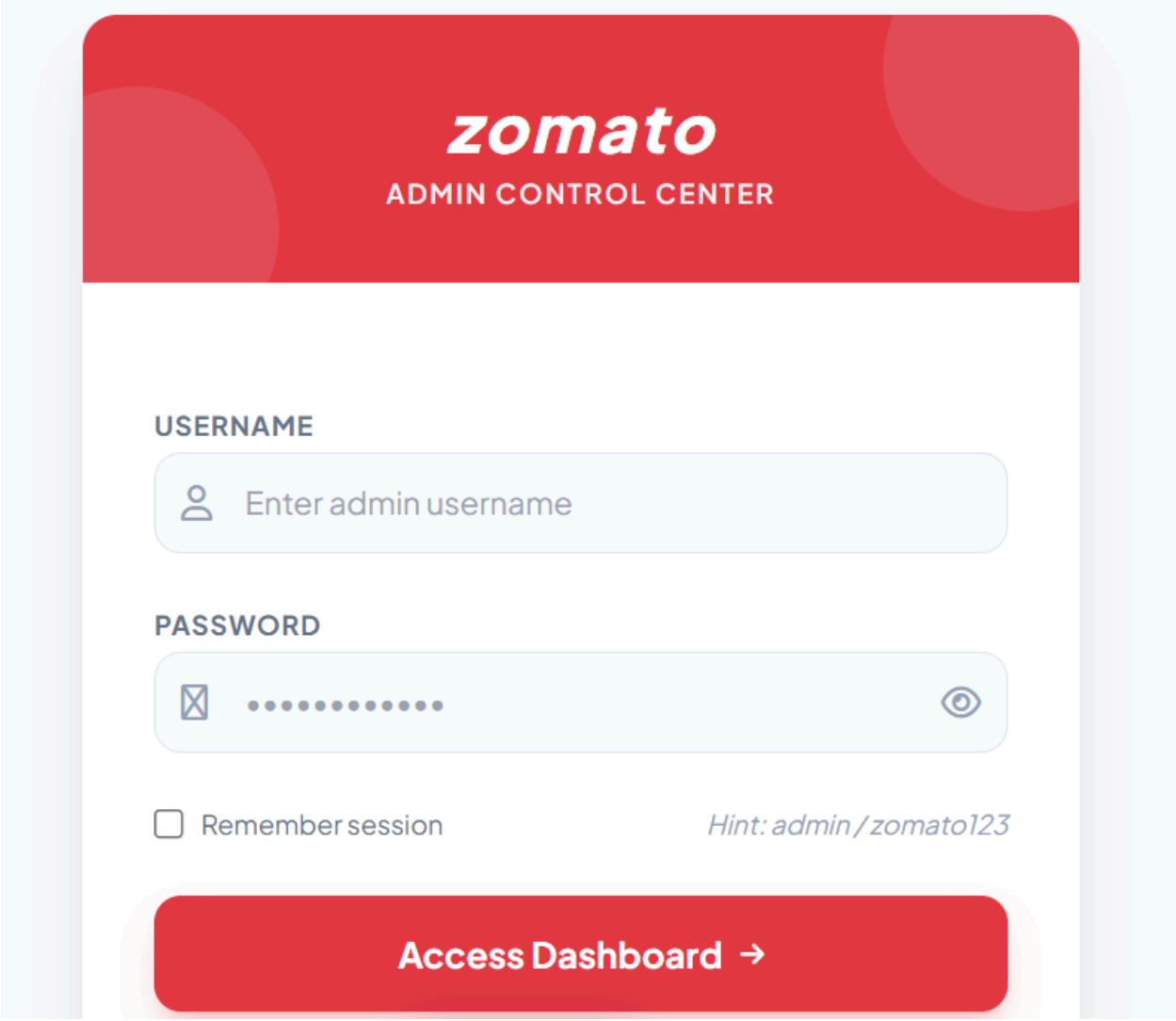
        // Handle Logout
        function handleLogout() {
            const dashboard = document.getElementById('dashboard-view');
            dashboard.classList.add('opacity-0', 'scale-95');

            setTimeout(() => {
                dashboard.classList.add('hidden');
                const loginCard = document.getElementById('login-card');
                loginCard.classList.remove('hidden', 'opacity-0',
'scale-95');

                // Clear inputs
                document.getElementById('username').value = '';
                document.getElementById('password').value = '';

document.getElementById('error-banner').classList.add('hidden');

                const submitBtn = document.getElementById('submit-btn');
                submitBtn.disabled = false;
                submitBtn.innerHTML = '<span>Access Dashboard</span><i
class="fa-solid fa-arrow-right text-xs"></i>';
            }, 300);
        }
    </script>
</body>
</html>
```



Write a Python function check_access(user_role, resource) that returns True if the user_role is allowed to access the resource, otherwise False. Test it with roles like 'customer', 'restaurant_owner', and resources like 'menu_edit', 'order_history', 'admin_dashboard'.

Hint: Use a dictionary to map roles to allowed resources.

ANS:

```
def check_access(user_role, resource):
    """
```

```
    Checks if a user role has permission to access a specific resource.
    """
    # Dictionary mapping each role to its allowed resources
    permissions = {
        'customer': {'order_history', 'view_restaurants'},
        'restaurant_owner': {'order_history', 'menu_edit', 'manage_orders'},
        'admin': {'order_history', 'menu_edit', 'manage_orders', 'admin_dashboard'}
    }

    # Retrieve the allowed resources for the given role; default to an empty set if role doesn't
exist
    allowed_resources = permissions.get(user_role, set())

    # Return True if the resource is in the allowed set, otherwise False
    return resource in allowed_resources


# --- Test Cases ---
if __name__ == "__main__":
    test_cases = [
        ('customer', 'order_history'),       # Expected: True
        ('customer', 'admin_dashboard'),    # Expected: False
        ('restaurant_owner', 'menu_edit'),   # Expected: True
        ('restaurant_owner', 'admin_dashboard'), # Expected: False
        ('admin', 'admin_dashboard'),        # Expected: True
        ('guest', 'order_history')           # Expected: False (unknown role)
    ]

    for role, res in test_cases:
        result = check_access(role, res)
        print(f"Role: {role:<18} | Resource: {res:<16} | Access: {result}")
```

Simulate a two-factor authentication flow like Paytm: after a user enters the correct password, generate a 6-digit OTP and display it in the console. Ask the user to input the OTP and display 'Login Successful' only if it matches.

ANS:

```
import random

def paytm_2fa_login():
    # Hardcoded mock credentials
    correct_username = "user123"
    correct_password = "securepassword123"

    print("=== Paytm Login Portal ===")

    # Step 1: Username & Password Verification
    username = input("Enter username: ")
    password = input("Enter password: ")

    if username == correct_username and password == correct_password:
        print("\n[+] Password verified successfully.")
        print("[*] Generating 6-digit OTP...")

        # Step 2: Generate a random 6-digit OTP (100000 to 999999)
        otp = random.randint(100000, 999999)

        # Step 3: Simulate sending SMS by displaying the OTP in the console
        print(f"\n📲 [SIMULATED SMS] Your Paytm verification code is: {otp}")

        # Step 4: Prompt user for OTP input
        user_otp = input("\nEnter the 6-digit OTP received via SMS: ")

        # Step 5: Validate OTP
        if user_otp.strip() == str(otp):
            print("\n✅ Login Successful! Welcome back.")
        else:
            print("\n❌ Login Failed: Incorrect OTP entered.")
    else:
        print("\n❌ Login Failed: Invalid username or password.")

if __name__ == "__main__":
    paytm_2fa_login()
```

Given an array of user objects with properties: username, isPremium, and lastLogin, write a function that returns only those users who are premium and have logged in within the last 7 days.

Constraint: Assume lastLogin is a date string in 'YYYY-MM-DD' format, and today is '2024-06-10'.

ANS:

```
from datetime import datetime, timedelta

def get_active_premium_users(users, current_date_str='2024-06-10'):
    """
    Returns users who are premium and have logged in within the last 7 days.
    """
    today = datetime.strptime(current_date_str, '%Y-%m-%d')
    cutoff_date = today - timedelta(days=7)

    active_premium_users = []

    for user in users:
        # Check if the user is premium
        if user.get('isPremium'):
            last_login = datetime.strptime(user.get('lastLogin'), '%Y-%m-%d')

            # Check if lastLogin falls within the 7-day window (inclusive of today)
            if cutoff_date <= last_login <= today:
                active_premium_users.append(user)

    return active_premium_users

# --- Example Usage ---
if __name__ == "__main__":
    mock_users = [
        {"username": "alice", "isPremium": True, "lastLogin": "2024-06-08"},   # Match (Within 7 days, premium)
        {"username": "bob", "isPremium": True, "lastLogin": "2024-05-20"},     # No match (Too old)
        {"username": "charlie", "isPremium": False, "lastLogin": "2024-06-09"}, # No match (Not premium)
        {"username": "diana", "isPremium": True, "lastLogin": "2024-06-03"},    # Match (Exactly 7 days ago)
        {"username": "evan", "isPremium": True, "lastLogin": "2024-06-02"},     # No match (8 days ago)
    ]

    result = get_active_premium_users(mock_users)

    print("Filtered Users:")
    for u in result:
```

```
print(f"- {u['username']} (Last Login: {u['lastLogin']})")
```

Use ChatGPT to generate a list of 5 common access control mistakes developers make in real-world apps like Instagram or Flipkart, and for each, write a one-line fix or prevention tip.

ANS:

IDOR: Enforce server-side ownership checks to verify resource access per user.

Client-Side Control: Validate all permissions and roles on the backend, never rely on frontend UI hiding.

Mass Assignment: Use strict allowlists to prevent users from modifying restricted fields like `is_admin`.

Broken Function-Level Control: Secure every sensitive admin/merchant endpoint with central authorization middleware.

Unverified JWT Claims: Cryptographically verify token signatures, expiration, and role status on the server.